

Beispiel für eine Datenschutzrichtlinie

Unser Unternehmen beachtet gesetzliche Vorschriften und achtet auf die Wahrung unserer wie auch der Betriebs- und Geschäftsgeheimnisse unserer Geschäftspartner. Das schließt alle Formen der bei uns praktizierten oder durch Outsourcing bei Dienstleistern durchgeführten Datenverarbeitung ein. Vor diesem Hintergrund ergeht folgende Richtlinie:

I. Grundsätze

1. Vermutete oder erwiesene Verstöße gegen Datensicherheit und Datenschutz („Datenpannen“) sind in unserem Unternehmen meldepflichtig gemäß den nachfolgenden Bestimmungen.
2. Die Meldepflicht wird für denjenigen Verantwortlichen ausgelöst, der in seinem Arbeitsbereich auf eine vermutete oder erwiesene „Datenpanne“ stößt oder hingewiesen wird. Mitarbeiter melden derartige Beobachtungen dem Vorgesetzten, der nach den nachfolgenden Bestimmungen verfährt.
3. Die hier festgelegte Meldepflicht bezieht sich auf interne Informationspflichten und deren Wege; inwieweit eine Offenlegung nach außen geboten ist, obliegt dem in Ziffer V bestellten Entscheidungsgremium.

II. Datenpannen

Als „Datenpannen“ werden alle schädlichen Ereignisse bei der Datenverarbeitung angesehen, die vom Datenschutzrecht geschützte personenbezogene Daten sowie solche Daten betreffen, die im Sinne unseres Unternehmens oder im Hinblick auf die Haftung gegenüber unseren Geschäftspartnern als schutzwürdig anzusehen sind (eigene und fremde Betriebs- und Geschäftsgeheimnisse).

Namentlich sind als „Datenpannen“ definiert:

1. Formen bewusster oder unbewusster unbefugter oder rechtswidriger Verarbeitung schutzwürdiger Daten.
2. Unbefugte Aktivitäten zur Umgehung von Sicherheitsvorkehrungen, die dem Schutz schutzwürdiger Daten dienen.
3. Angriffe auf die IT-Infrastruktur des Unternehmens, die vermutlich oder offensichtlich erfolgreich waren.

Unter „Verarbeitung von Daten!“ ist zu verstehen:

- Erhebung,
- Speicherung,
- Veränderung,
- Abruf,
- Einsicht,
- Löschung,
- Nutzung von Daten.

III. Wahrnehmung von Datenpannen

Datenpannen können unterschiedlich wahrgenommen werden. Zu unterscheiden ist zwischen „intern“ und „extern“:

1. Von innen:
 - Alarme aufgrund von Warnmechanismen
 - Anomalien in der Verarbeitung schutzwürdiger Daten
 - Erkenntnisse aus dem Incident Handling sowie dem Problem Management
 - Erkenntnisse aus Prüfungen
 - Erkenntnisse aus Mitarbeitergesprächen
2. Von außen:
 - Hinweise Dritter
 - Medienberichte
 - Anzeigen

IV. Berichtswege und interne Abstimmung

1. Mitarbeiter, die eine tatsächliche oder vermutete Datenpanne wahrnehmen, informieren unverzüglich
 - ihren Vorgesetzten und gleichzeitig
 - den betrieblichen Datenschutzbeauftragten.
2. Ist eine dieser beiden Personen abwesend, handelt der jeweils andere allein; im Regelfall unternehmen sie gemeinsam folgende Schritte:
 - Anfertigen eines als „vertraulich“ gekennzeichneten Protokolls, das die Erkenntnisse des meldenden Mitarbeiters beschreibt.
 - Verteilung des Protokolls an:
3. „Pflichtempfänger“:
 - Geschäftsführung,
 - Leiter der Abteilungen, welche die Datenpanne berührt,
 - IT-Sicherheitsbeauftragter,
 - Rechtsabteilung,
 - Werkssicherheit,
 - Interne Revision.
4. „fallorientierte Empfänger“:
 - Einkauf, soweit Fremdfirmen betroffen sind oder sein können,
 - Vertrieb, soweit Vertriebsstrukturen berührt sind oder sein können,
 - Personalleitung, soweit es Hinweise auf Fehlverhalten von Beschäftigten gibt (die Personalleitung informiert seinerseits den Betriebsrat, sofern es sich um Tatbestände der Mitbestimmung nach dem Betriebsverfassungsgesetz handelt).
3. Das Protokoll und die Ergebnisse weiterer Recherchen stehen dem Wirtschaftsprüfer zur Verfügung, der den Jahresabschluss zu testieren und dabei die Wirksamkeit des Internen Kontrollsystems (IKS) auf der Grundlage des Aktiengesetzes und der Grundsätze ordnungsmäßiger DV-gestützter Buchführungssysteme (GoBS) zu prüfen und zu testieren hat.

V. Klärung des Sachverhalts und Aktionen

1. Über das weitere Vorgehen entscheidet die Geschäftsführung nach Anhörung des IT-Sicherheitsbeauftragten, des betrieblichen Datenschutzbeauftragten und der Leiter der Abteilungen, die von der Datenpanne berührt sind.
2. Zu klären ist, inwieweit
 - Strafanzeige zu erstatten ist,
 - personelle Maßnahmen zu ergreifen sind,
 - eine Zusammenarbeit mit einem betroffenen Unternehmen zu beenden ist,
 - Haftungsansprüche geltend gemacht werden können,
 - eine Benachrichtigung der Aufsichtsbehörde für den Datenschutz erforderlich ist,
 - von der Datenpanne betroffene Personen einzeln zu benachrichtigen sind, wahlweise eine allgemeine Anzeige auf der Webseite des Unternehmens durchzuführen ist,
 - Änderungen in bestehenden Verfahren vorzunehmen sind, um Wiederholungen zu vermeiden.
3. Das Ergebnis wird protokolliert und steht neben den unter IV genannten „Empfängern“ dem Wirtschaftsprüfer zur Verfügung.

VI. Hinweise

1. Alle Vorkommnisse werden intern und vertraulich behandelt. Über eine Veröffentlichungspflicht entscheidet eine Prüfung durch die Geschäftsführung im Benehmen mit dem betrieblichen Datenschutzbeauftragten.
2. Beschäftigte, die vermutete oder tatsächliche Datenpannen wahrgenommen und gemeldet haben, erleiden keinerlei Nachteile aus der Tatsache, dass sie gemäß dieser Richtlinie gehandelt haben.